

MiniCISO Staff

Service Catalog v4 — catálogo completo com QA, evidência em camadas, Divergência de Configuração, BBP Specialist, RASS e Watchman supply-chain silencioso

V3 Upgrade	Incorpora Divergência de Configuração, evidência em camadas, security-supply-chain Watchman silencioso e adiciona explicitamente BBP Specialist e RASS ao catálogo oficial.
Fluxo obrigatório	Usuário → MiniCISO → SME Especializado → Security QA → MiniCISO → Usuário. Para BBP: Usuário → MiniCISO → BBP Specialist → SME(s) de apoio → Security QA → MiniCISO → Usuário
Guardrail	Sem remediação automática. Relatórios finais exigem 7 seções e QA. BBP exige authorization gate. Work ofensivo exige autorização, escopo, limites e critérios de parada.

Versão oficial: v4 • Data: 24/06/2026 • Catálogo completo consolidado do MiniCISO Staff

1. Executive Summary

O catálogo v4 consolida o MiniCISO Staff em um modelo operacional auditável, com QA, evidência em camadas, governança BBP, recon estratégico de baixo ruído e autorização explícita para trabalho ofensivo.

Coordenação

MiniCISO recebe demanda, triagem escopo/risco, aciona SME e consolida resposta final.

Especialização

SMEs produzem análise técnica dentro do domínio e declaram assumptions, confidence e residual risk.

QA obrigatório

Security QA valida evidência, severidade, overclaiming, divergências e 7 seções antes da entrega.

Evidência

Toda análise diferencia configuração declarada, runtime efetivo e comportamento validado.

Divergência

Conflito entre declarado/runtime/comportamento vira achado próprio: Divergência de Configuração.

Watchman

Supply-chain opera silencioso, read-only, high precision e sem remediação automática.

Seções obrigatórias para relatórios MiniCISO

- Executive Summary
- Findings
- Recommendations
- Assumptions
- Confidence Level
- Residual Risk
- Next Steps

Confidence Level: High, Medium ou Low. Residual Risk: LOW, MEDIUM, HIGH ou CRITICAL.

2. Findings — mudanças v4 sobre v3

Evidência	Separação obrigatória: declarada, runtime/efetiva e comportamento validado.	Evita concluir segurança apenas por arquivos, UI ou relatos.
Divergência	Nova classificação: Divergência de Configuração, com investigação específica.	Torna explícito quando o controle não se comporta como declarado.
QA	QA passa a validar divergências, overclaiming, risco residual e formato obrigatório.	Impede relatórios finais sem qualidade metodológica.
Supply chain	Watchman silencioso, read-only, com alerta apenas high-confidence e acionável.	Reduz ruído e evita fadiga de CVEs sem impacto plausível.
BBP	Inclusão explícita de security-bbp-specialist para governança de Bug Bounty/VDP, policy, scope, safe harbor, authorization gate e report em inglês.	Separa governança BBP de OffSec e reduz risco operacional, reputacional e de escopo.
Recon	Inclusão explícita de security-recon-attack-surface-strategist (RASS) para recon de baixo ruído, triagem de superfície e priorização de hipóteses.	Melhora seleção de próximos gates sem promover sinais a findings antes da validação adequada.
Remediação	Nenhum update, restart, alteração de firewall/config/cron/serviço sem aprovação explícita.	Separa recomendação técnica de execução operacional autorizada.

3. Modelo de evidência v3

Toda conclusão de risco deve indicar o tipo de evidência usado e seus limites.

Configuração declarada

Arquivos, IaC, políticas, dashboards, documentação e relatos do usuário. Boa para intenção; limitada para efetividade.

Runtime / configuração efetiva

Saída de daemon, systemd, listeners, regras carregadas, config parseada e estado real em execução.

Comportamento validado

Teste real: login, conexão, scan, bloqueio/allow, restore, alerta observado. Mais forte para decisões de risco.

Regra de decisão

- Não inferir comportamento apenas a partir de configuração declarada.
- Quando houver conflito, priorizar runtime e comportamento para avaliação de risco.
- Evidência declarada isolada deve limitar Confidence Level.
- Evidência fornecida pelo usuário é válida, mas deve ser rotulada como relatada se não houver artefato auditável.

Formato recomendado para achados: Controle; Evidência declarada; Runtime/efetiva; Comportamento; Conclusão; Confidence; Residual Risk; Próxima validação.

4. Divergência de Configuração

Correção metodológica permanente para controles que não se comportam conforme declarado.

Classificação

Usar exatamente: Divergência de Configuração.

Investigação

Criar item específico; não tratar como detalhe colateral do finding.

Neutralidade

Não assumir que funciona; não assumir que está quebrado em todos os contextos sem evidência.

Campos obrigatórios

- Controle afetado
- Estado declarado
- Estado runtime/efetivo
- Comportamento observado
- Impacto plausível
- Hipóteses de causa
- Validação adicional necessária
- Recomendação
- Owner sugerido
- Severidade e Confidence Level

Exemplo: Declarado: PasswordAuthentication no. Runtime: sshd -T retorna passwordauthentication yes. Comportamento: login por senha bem-sucedido. Classificação: Divergência de Configuração.

5. Staff map e catálogo de serviços v4

security-threat-modeling	Ativos, atores, trust boundaries, fluxos críticos, abuse cases, priorização estratégica.	Threat Model; riscos priorizados; backlog de controles.	Fluxo/diagrama, dados, atores, fronteiras, objetivo.
security-architecture	SSH, firewall, rede, cloud, systemd, túneis, gateway, exposição de serviços, divergências de infra.	Architecture Review; decisões; plano seguro; tradeoffs.	Desenho atual/alvo, configs, runtime, comportamento, constraints.
security-code-review	Repo, diff, scripts, padrões de auth/secrets/injection e lógica sensível.	Findings por arquivo/linha; correções; testes.	Repo/path/diff, linguagem, foco de risco, permissão de testes.
security-appsec-assessment	APIs, endpoints, authz/authn, sessão, SAST, DAST, SCA, containers, IaC.	AppSec assessment; priorização; falso positivo; backlog.	Scanner outputs, SARIF, SBOM, manifests, repo, escopo.
security-offensive-security	Validação ofensiva autorizada, segura e defensável; interpretação de scanners e PoCs em lab.	Plano de teste; evidências; critérios de parada; remediações.	Autorização, alvo, janela, limites, sem DoS/persistência.
security-compliance-mapper	Mapear achados para PCI, LGPD, GDPR, ISO 27001, SOC2, CIS, NIST, DORA.	Gap matrix; mapping; readiness; roadmap.	Framework, políticas, processos, evidências, escopo.
security-supply-chain	SBOM, CVEs, advisories, pacotes Ubuntu/Python/Docker, incidentes e monitoramento contínuo.	Alertas high-confidence; digest mensal; inventário/SBOM.	Inventário, SBOM, versões, exposição, critérios de alerta.
security-bbp-specialist	Programas de Bug Bounty/VDP/Challenge: policy, scope, safe harbor, authorization gate, evidence minimization, report em inglês e submissão.	Decisão de GO/NO-GO; gate formal; report externo; acompanhamento de submissão.	Programa, policy URL, scope atual, researcher eligibility, restrições e stop criteria.
security-recon-attack-surface-strategist	Recon autorizado de baixo ruído, mapeamento e triagem de attack surface, priorização de hipóteses e ordem segura de validação.	Surface map; hipóteses priorizadas; próximos gates sugeridos; backlog de investigação.	Família de alvos, constraints, policy, orçamento de requests e sinais já observados.
security-qa	Quality gate obrigatório antes de entrega final, addendum, mudança de severidade ou divergência.	Aprovado / ressalvas / reprovado; correções.	Draft, escopo, evidências, público-alvo, critérios MiniCISO.

6. Threat Modeling

security-threat-modeling

Capabilities

- STRIDE e abuse cases
- Ativos, atores, trust boundaries
- Controles defensivos e backlog
- Priorizar cenários por impacto/probabilidade

Entrada ideal

Faça uma threat model de [sistema/fluxo]. Contexto: [objetivo]. Artefatos: [diagrama/fluxo]. Dados sensíveis: [lista]. Atores: [lista]. Quero riscos priorizados, recomendações, assumptions, confidence level, residual risk e next steps. Passe pelo Security QA.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

7. Security Architecture

security-architecture

Capabilities

- IAM/auth/logging/secrets
- Cloud, rede, segmentação, SSH, firewall, tunnels
- Divergência config/runtime/comportamento
- Plano de correção seguro sem remediação automática

Entrada ideal

Revise esta arquitetura/controle. Stack: [stack]. Declarado: [configs]. Runtime: [outputs]. Comportamento: [testes]. Constraints: [prazo/custo/risco]. Quero recomendações priorizadas, divergências, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

8. Secure Code Review

security-code-review

Capabilities

- Revisão manual
- Arquivo/linha/evidência
- Correção e teste
- Hardening vs vulnerabilidade

Entrada ideal

Revise segurança do código em [path/diff]. Foco: [categorias]. Pode executar testes locais: [sim/não]. Quero findings, falso positivo se aplicável, remediação proposta, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

9. AppSec Assessment

security-appsec-assessment

Capabilities

- SAST/DAST/SCA/SBOM
- API/auth/session/secrets
- Containers, Kubernetes, IaC
- Explorabilidade e priorização

Entrada ideal

Avalie os findings de AppSec deste projeto. Artefatos: [scanner outputs], [SARIF], [SBOM], [repo]. Objetivo: [reduzir risco/validar findings/priorizar backlog]. Quero confirmados, falso positivos, priorização, remediação proposta, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

10. BBP Specialist

security-bbp-specialist

Capabilities

- Program policy, scope e safe harbor
- Authorization gate e stop conditions
- Evidence minimization e report em inglês
- Submissão, triage e retrospective learning

Entrada ideal

Avalie este programa BBP/VDP/Challenge. Artefatos: [policy], [scope], [regras], [asset list]. Objetivo: decidir GO/NO-GO, limites, autorização, setup e formato do report. Quero authorization gate, restrições, evidência mínima, assumptions, confidence, residual risk e next steps. Passe pelo Security QA antes de qualquer submissão externa.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

11. Recon / Attack Surface Strategist

security-recon-attack-surface-strategist

Capabilities

- Recon autorizado de baixo ruído
- Mapeamento e triagem de superfícies candidatas
- Priorização de hipóteses e próximos gates
- Chain: Signal → Hypothesis → Safe validation → Impact proof → QA → Report

Entrada ideal

Faça triagem de attack surface para [programa/alvo] dentro do escopo autorizado. Restrições: [rate limits / no-noise / read-only / docs only]. Sinais atuais: [lista]. Quero superfícies candidatas, hipóteses priorizadas, ordem segura de validação, NO-GO areas, assumptions, confidence, residual risk e next steps. Não promover sinais a finding final sem validação posterior.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

12. Offensive Security Autorizado

security-offensive-security

Capabilities

- Testes controlados
- Safe PoCs locais/lab
- Interpretação de scanner
- Critérios de parada e reporte seguro

Entrada ideal

Tenho autorização para testar [alvo] no escopo [IPs/domínios/apps], janela [data/hora], limites [sem DoS/sem persistência/etc]. Objetivo: validar [risco]. Gere metodologia segura, evidências esperadas, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

13. Compliance Mapper

security-compliance-mapper

Capabilities

- PCI DSS, LGPD, GDPR, ISO 27001/27002
- SOC2, CIS, NIST CSF/800-53, DORA
- Gap analysis e readiness
- Traceability e evidence review

Entrada ideal

Mapeie estes controles para [framework]. Objetivo: [auditoria/readiness/roadmap]. Artefatos: [políticas], [arquitetura], [processos], [evidências]. Quero gap matrix, mapping, readiness, roadmap, assumptions, confidence, residual risk e next steps. Passe pelo Security QA.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

14. Security Supply Chain Watchman

security-supply-chain

Capabilities

- Correlação advisories 12h
- Inventário/SBOM semanal
- Alertas somente high-confidence e acionáveis
- Digest mensal mesmo sem alertas

Entrada ideal

Monitore supply chain para [ambiente]. Critérios: alertar só se componente presente, impacto plausível, ação recomendada, confidence >= high e cooldown/exceção crítica. Não executar update/remediação automática. Produzir digest mensal de saúde.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

15. Security QA

security-qa

Capabilities

- 7 seções obrigatórias
- Evidência declarada/runtime/comportamento
- Divergência de Configuração
- Overclaiming, severidade, confidence e residual risk

Entrada ideal

Revise este draft como Security QA. Público-alvo: [executivo/técnico]. Escopo autorizado: [escopo]. Evidências: [artefatos]. Verifique 7 seções, evidência em camadas, divergências, segurança, clareza e diga Aprovado, Aprovado com ressalvas ou Reprovado.

Outcome máximo

- Inclua artefatos reais e paths concretos.
- Declare objetivo de decisão e escopo autorizado.
- Separe declarado, runtime e comportamento quando aplicável.
- Informe restrições, público-alvo e ações permitidas.
- Passe pelo Security QA para qualquer entrega final.

16. Recommendations — intake universal

Objetivo	Decisão ou resultado esperado.	Priorizar backlog de segurança para MVP ou corrigir divergência SSH.
Escopo	Inclui/exclui, alvo, ambiente, limites, autorização.	Apenas VPS irlan.tech; excluir terceiros; sem testes destrutivos.
Artefatos	Repo, diff, scanner output, SARIF, SBOM, configs, logs, screenshots.	/etc/ssh/sshd_config, sshd -T, tentativa real de login.
Evidências	Declarada, runtime e comportamento; marcar o que não foi validado.	Declarado: no; runtime: yes; comportamento: senha funcionou.
Ações permitidas	Análise, testes, escrita de relatório, remediação aprovada ou proibida.	Sem update automático; plano de correção seguro apenas.
Formato	Público, profundidade, QA e saída desejada.	Resumo executivo + backlog técnico; passar por Security QA.

Template universal

Quero [serviço] para [sistema/artefato]. Objetivo: [decisão]. Escopo autorizado: [inclui/exclui]. Artefatos: [paths/outputs]. Evidência declarada: [x]. Runtime: [y]. Comportamento validado: [z]. Assumptions conhecidas: [lista]. Restrições e ações permitidas: [lista]. Saida: relatório com Executive Summary, Findings, Recommendations, Assumptions, Confidence Level, Residual Risk e Next Steps. Passe pelo Security QA.

17. Assumptions

- O catálogo é uma referência operacional para o MiniCISO Staff de Irlan e não substitui auditoria formal ou parecer jurídico.
- As decisões de remediação continuam exigindo aprovação explícita do usuário quando houver side effects.
- Evidências de usuário podem ser usadas, mas devem ser rotuladas e qualificadas conforme auditabilidade.
- Work ofensivo ativo depende de autorização, alvo, escopo, limites e critérios de parada.

18. Confidence Level

High para a aderência metodológica do catálogo v4 aos requisitos atuais do MiniCISO Staff, porque ele incorpora QA obrigatório, 7 seções, evidência em camadas, Divergência de Configuração, Watchman silencioso, governança BBP, RASS e proibição de remediação automática.

Medium para efetividade operacional futura, pois depende da disciplina de uso, qualidade dos artefatos fornecidos, passagem real pelo Security QA e validação concreta dos controles em cada caso.

19. Residual Risk

- MEDIUM: o catálogo reduz risco metodológico, mas não garante que todos os relatórios futuros terão evidência runtime/comportamental suficiente.
- MEDIUM: Watchman silencioso reduz ruído, mas pode suprimir advisories de baixa confiança que venham a se tornar relevantes depois.
- LOW/MEDIUM: remediação manual evita mudanças não autorizadas, mas cria dependência de aprovação humana para correções urgentes.
- HIGH se trabalho ofensivo for solicitado sem escopo/autorização; nesses casos o fluxo deve parar e pedir autorização explícita.

20. Next Steps e QA checklist

Fluxo Usuário → MiniCISO → SME → QA → MiniCISO → Usuário declarado, com trilha BBP quando aplicável	Obrigatório
7 seções obrigatórias presentes para relatórios	Obrigatório
Evidência declarada/runtime/comportamento separada	Obrigatório quando aplicável
Divergência de Configuração classificada explicitamente	Obrigatório quando houver conflito
Supply-chain Watchman silencioso, high-confidence, sem remediação automática, com BBP Specialist e RASS explícitos no catálogo	Obrigatório
Offensive work exige autorização, escopo, limites e parada	Obrigatório
PT-BR Markdown com UTF-8 BOM quando arquivo .md for entregue	Obrigatório

Security QA status: aprovado com ressalva operacional — a metodologia v4 está adequada; a qualidade final de cada entrega dependerá da evidência concreta recebida e da passagem real pelo QA.